

Лекция 12

Угрозы безопасности информации на прикладном уровне модели OSI

(Рассмотрим базовые угрозы уровней 5, 6 и 7 модели OSI, соответствующие прикладному уровню TCP/IP. Многие приложения уязвимы для эксплойтов, особенно на верхних уровнях модели).



Учебные вопросы:

1. Система доменных имен BIND (DNS).
2. Веб-сервер Apache.
3. Системы контроля версий.
4. Агенты передачи сообщений.
5. Защита работающих служб

Дополнительный материал:



BIND

Berkeley Internet Domain Name

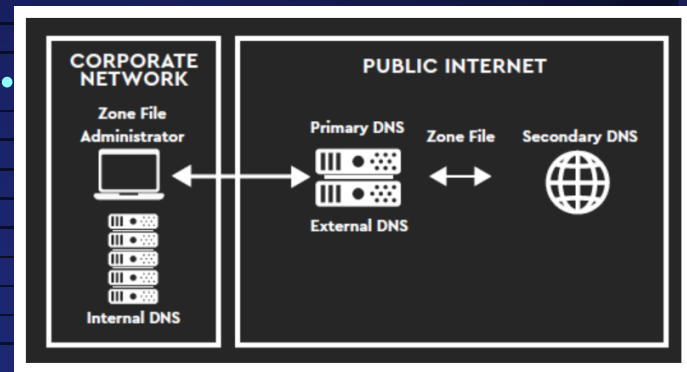
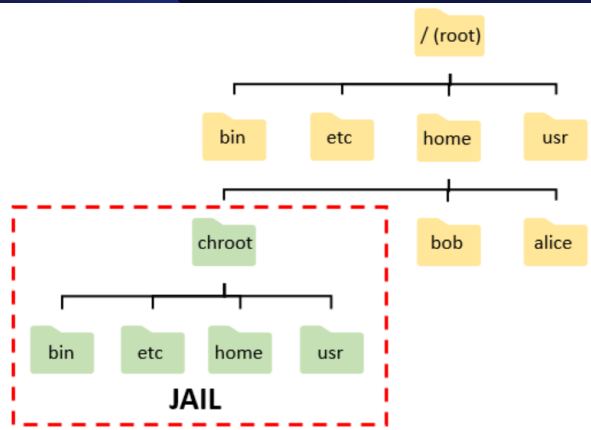
Система доменных имен BIND (DNS)

BIND (Berkley Internet Name Domain) – самый популярный DNS-сервер в интернете. Для работы ему нужно взаимодействовать с множеством других DNS-серверов, что делает фильтрацию DNS-пакетов невозможной.

DNS-сервисы важны для работы интернета, поэтому злоумышленники могут отключать DNS-серверы. Хотя BIND известен проблемами безопасности, которые можно исправить, существует множество уязвимых серверов, поэтому важно быть осторожным при работе с ним.

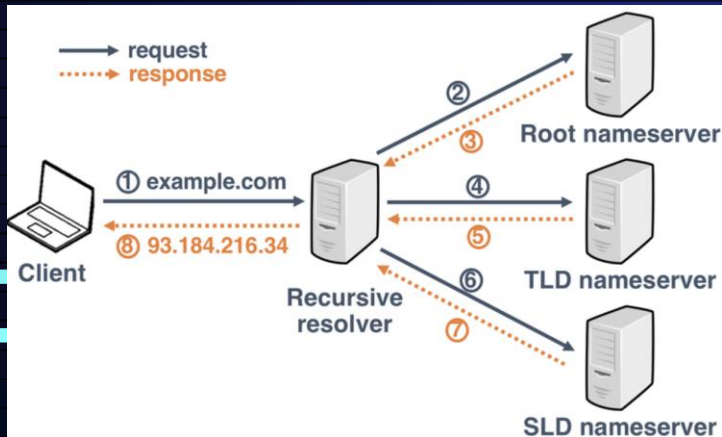
Опрос DNS-серверов

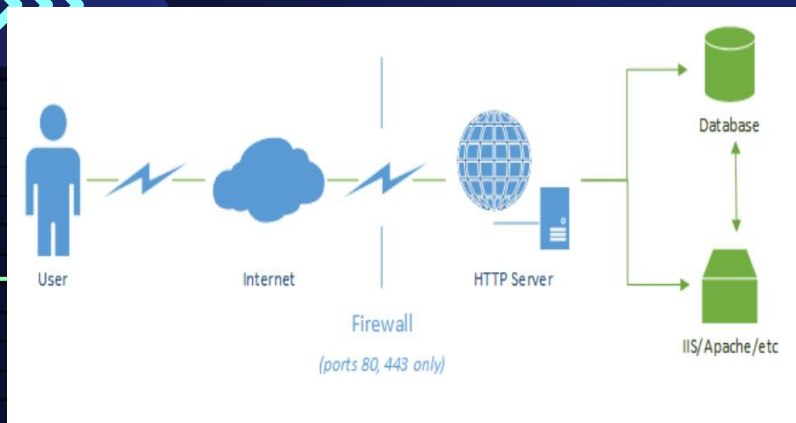
Number of domains serviced by each program		
70.105%	24,335,752	BIND
15.571%	5,405,266	TinyDNS
6.237%	2,165,143	Microsoft DNS Server
2.792%	969,097	MyDNS
1.964%	681,614	PowerDNS
1.250%	433,905	Simple DNS Plus
1.138%	395,206	Unknown
0.277%	96,232	Plant DNS Server
0.203%	70,455	NSD
0.144%	49,921	UltraDNS
0.104%	36,195	Net::DNS::Nameserver
0.083%	28,656	QuickDNS
0.064%	22,087	Incognito DNS Commander
0.025%	8,508	MaraDNS
0.024%	8,174	rbldnsd
0.018%	6,135	Totd
0.001%	386	ATLAS
0.001%	371	Posadis
0.001%	312	NonSequitur DNS
0.000%	12	Nomimum ANS/CNS



Советы по безопасности BIND:

1. Используйте последнюю версию BIND с официального сайта (<http://www.isc.org>).
2. Поместите BIND в chroot-jail для защиты от уязвимостей.
3. Регулярно применяйте обновления и исправления.
4. Защитите зону между DNS-серверами с помощью TSIG.
5. Отключите рекурсию.
6. Рассмотрите использование TinyDNS как более безопасного альтернативного решения.





Веб-сервер Apache

Apache — самый популярный веб-сервер с историей проблем безопасности. Для повышения его безопасности:

- * Обновляйте и поддерживайте сервер в актуальном состоянии.
- * Удалите примеры скриптов дополнительных модулей.
- * Используйте suEXEC для сценариев с другим идентификатором пользователя.
- * Запретите загрузку скриптов от ненадежных источников.
- * Запускайте сервер от пользователя с минимальными правами.
- * Измените токен ответа для усложнения атак.

Системы контроля версий

Предоставляют разработчикам инструменты для работы с файлами и управления версиями кода.

CVS

Классическая популярная в Linux, CVS (Concurrent Versions System) использовалась в проектах с открытым исходным кодом. Уязвимости включают переполнение буфера кучи и команд, позволяющие выполнять произвольный код.

Для защиты:

- * Обновите CVS.
- * Запустите в chroot-окружении.
- * Используйте SSH вместо pserver.
- * Отфильтруйте порт 2401 для доверенных хостов.
- * Для анонимного доступа разместите сервер только для чтения на автономной системе.
- * Проверьте сервер на эксплойты.

Subversion

Популярная в Linux система контроля версий. Уязвимости: переполнение буфера кучи и стека, позволяющие неаутентифицированным пользователям выполнять произвольный код.

Для защиты:

- * Обновите Subversion.
- * Настройте webDAV вместо svn.
- * Отфильтруйте порт 3690 для доверенных хостов.
- * Размещайте сервер для анонимного доступа только для чтения на автономной системе.
- * Проверьте сервер на эксплойты.

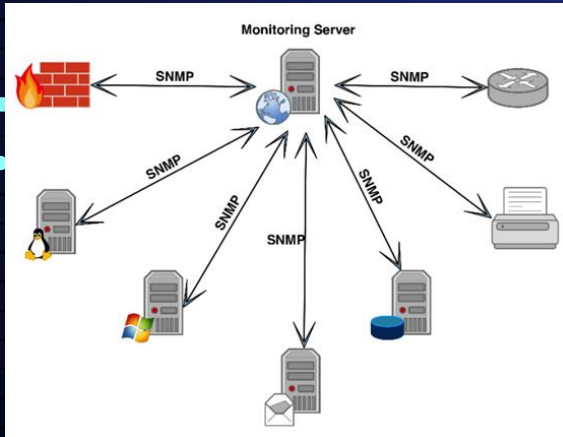
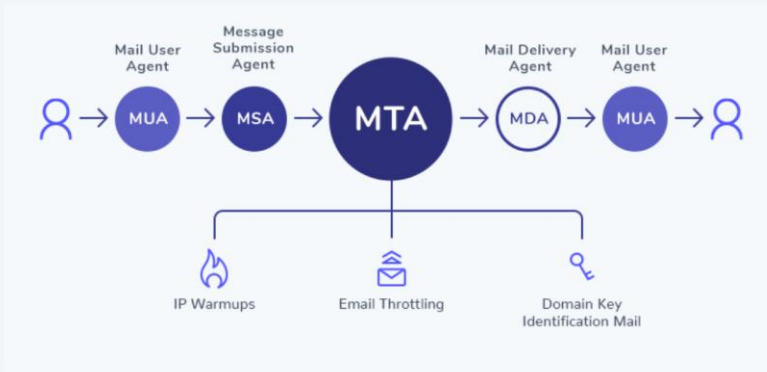
Агенты передачи сообщений (MTA - Mail Transport Agents)

Электронная почта — ключевой сервис в Интернете для компаний. SMTP (Send Mail Transport Protocol) используется для отправки почты через TCP-порт 25 и не подлежит фильтрации.

Sendmail, ранее популярный MTA для Linux, имел серьезные проблемы с безопасностью, включая уязвимости для атак. Альтернативы: Postfix, Qmail, Exim, Courier-MTA.

Основные проблемы MTA:

- * Уязвимости (переполнение буфера, кучи и др.), позволяющие злоумышленникам компрометировать сервер.
- * Неправильная конфигурация, ведущая к открытой ретрансляции и использованию сервера спамерами, что может привести к блокировке и снижению пропускной способности.
- * Утечки данных учетных записей.



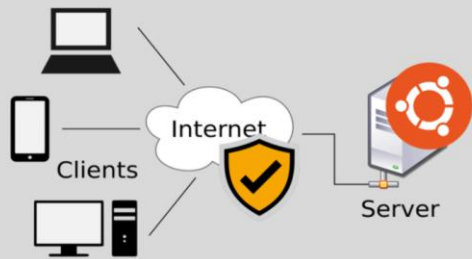
Протокол управления сетью SNMP

Большинство сетевых устройств используют для удаленного мониторинга и настройки. SNMP - это простой протокол, обычно используемый для создания программного обеспечения для мониторинга, которое может получать такую информацию, как сетевой трафик, загрузка ЦП, загрузка диска и т. д., а также изменять конфигурацию устройств, таких как беспроводное оборудование, маршрутизаторы и т. д.

Версии 1 и 2 SNMP используют строки сообщества (community string) для аутентификации. Они отправляются через UDP-порт 161 в незашифрованном виде. Когда вы настраиваете SNMP на устройстве (включая систему Linux), вы должны настроить две строки сообщества: одну с доступом только для чтения и по умолчанию общедоступную (public), а другую с доступом для чтения и записи и по умолчанию частную (private). Если этого не сделать, при отсутствии межсетевого экрана очень легко просмотреть их конфигурацию и изменить её.

Сделать:

- * Старайтесь не использовать SNMP, если в этом нет необходимости.
- * По возможности используйте SNMP версии 3, которая имеет аутентификацию в пользовательском режиме и может выполнять шифрование.
- * Настройте межсетевой экран на устройстве или на устройстве перед ним, разрешая только доверенным узлам подключаться с использованием SNMP.



OpenSSL
Cryptography and SSL/TLS Toolkit

OpenSSL

OpenSSL — популярная библиотека для криптографической поддержки сетевых приложений, таких как Apache, Sendmail, OpenLDAP и OpenSSH. Уязвимости в OpenSSL могут использоваться для выполнения произвольного кода или получения привилегий root. В прошлом уязвимости OpenSSL нанесли значительный ущерб, особенно для Apache, Sendmail и OpenSSH.

Как защититься:

1. Проверьте версию OpenSSL на серверах. Обновите до последней.
2. Перекомпилируйте приложения, использующие OpenSSL, при необходимости.
3. Настройте межсетевой экран для ограничения доступа.

Защита работающих служб:

1. Определите открытые порты и службы.
2. Обновите службы до последней версии.
3. Настройте конфигурации для доступа только доверенным хостам.
4. Ограничьте доступ межсетевым экраном.
5. Проведите аудит сети и симулируйте атаки.
6. Ведите журналы аутентификации и используйте системы обнаружения вторжений.

Некоторые шаги можно пропустить для локальных служб.